RÉPUBLIQUE DU CAMEROUN
****
Paix – Travail – Patrie
****
Université de Yaoundé 1
****
Ecole Nationale Supérieure Polytechnique De Yaoundé
****
Département Du Génie Informatique

REPUBLIC OF CAMEROON
****
Peace – Work – Fatherland
****
University of Yaoundé 1
****
National Advanced School of Engineering Of Yaoundé
****
Computer Engineering Department

AUDIT, ANALYSE DE RISQUES ET GESTION DE CRISE

CHARTE DE GOUVERNANCE — CAS LIZBIZ

Option :

Cybersécurité et Investigation Numérique

Rédigé par :

NGWAMBE BEKWADI MARIELLA, 22P040

Sous l'encadrement de :

M. Thierry MINKA

Année académique 2025-2026

Table des matières

INTRODUCTION **4**

1 Principes et Cadre de Gouvernance **5**

1.1 Contexte et Justification 5

1.2 Cadre de Référence 5

1.3 Principes Directeurs 6

1.4 Périmètre d'Application 6

2 Organisation, Rôles et Matrice RACI **7**

2.1 Organigramme de Gouvernance Cible 7

2.2 Rôles et Responsabilités 7

2.2.1 Direction Générale 7

2.2.2 RSSI — Responsable de la Sécurité des Systèmes d'Information . . 7

2.2.3 DSI — Direction des Systèmes d'Information 8

2.2.4 Équipe Technique 8

2.2.5 Comité de Sécurité 8

2.3 Matrice RACI — Gestion des Incidents Critiques 8

3 Processus de Décision et Gestion des Risques **10**

3.1 Processus de décision en matière de sécurité 10

3.1.1 Niveaux de décision 10

3.1.2 Procédure de Validation des Accès 10

3.2 Identification et Classification des Risques 11

3.2.1 Méthode d'Évaluation 11

3.2.2 Traitement des Risques 11

3.3 Gestion des Incidents 11

3.3.1 Niveaux de Criticité 11

3.3.2 Délais de Traitement et Rapport 12

4 Contrôle, Conformité et Éthique **13**

4.1 Mécanismes de Contrôle Interne 13

4.1.1 Fondement : ISO 19011 :2018 13

4.1.2 Programme d'Audit 13

4.1.3 Plan d'Audit et Conduite 14

4.1.4 Rapport d'Audit et Suivi 14

4.1.5 Revues d'Accès . . . 14
4.1.6 Journaux d'Activité . . . 15
4.2 Conformité Réglementaire . . . 15
4.2.1 Cadre Légal Applicable . . . 15
4.2.2 Registre de Conformité . . . 15
4.3 Éthique et Obligations des Collaborateurs . . . 15
4.3.1 Code de Conduite Numérique . . . 16
4.3.2 Sanctions . . . 16
4.4 Gestion des Prestataires Externes . . . 16

5 Communication, Suivi et Amélioration 17
5.1 Communication Interne . . . 17
5.1.1 Diffusion de la Charte . . . 17
5.1.2 Sensibilisation et Formation . . . 17
5.1.3 Communication en Cas de Crise . . . 17
5.2 Indicateurs de Suivi . . . 18
5.2.1 Tableau de Bord SSI . . . 18
5.2.2 Revue Annuelle de la Charte . . . 18
5.3 Amélioration Continue . . . 18
5.3.1 Retour d'Expérience . . . 18
5.3.2 Plan d'Amélioration . . . 19

Conclusion Générale 20

INTRODUCTION

La sécurité des systèmes d'information est aujourd'hui un enjeu stratégique incontournable pour toute organisation, quelle que soit sa taille. Dans un environnement numérique en constante évolution, les entreprises en croissance rapide sont particulièrement exposées aux risques liés à l'absence de structures de gouvernance formalisées. LiZbiZ illustre parfaitement cette réalité.

Face à la vacance du poste de Responsable de la Sécurité des Systèmes d'Information (RSSI), au cumul de fonctions incompatibles au sein de la Direction des Systèmes d'Information, et à l'absence de tout processus formalisé de gestion des incidents, nous nous sommes proposer de produire une charte de gouvernance simple, lors du prochain Comité de Direction.

La présente charte a pour ambition de doter LiZbiZ d'un cadre clair, traçable et défendable, définissant les principes directeurs, les rôles et responsabilités, les processus de décision, les mécanismes de contrôle ainsi que les modalités de communication et d'amélioration continue en matière de sécurité des systèmes d'information.

Ce document est structuré en cinq chapitres complémentaires. Le premier pose les **principes et le cadre de gouvernance** retenus. Le deuxième définit l'**organisation, les rôles et la matrice RACI**. Le troisième décrit les **processus de décision et de gestion des risques**. Le quatrième traite du **contrôle, de la conformité et de l'éthique**. Le cinquième, enfin, aborde la **communication, le suivi et l'amélioration continue**.

Chapitre 1

Principes et Cadre de Gouvernance

1.1. Contexte et Justification

LiZbiZ est une entreprise qui présente des problèmes habituels de plusieurs entreprises. La Direction Générale, focalisée sur les objectifs commerciaux, n'a pas anticipé la nécessité de formaliser une politique de sécurité. Le poste de RSSI est vacant, la DSI cumule des fonctions incompatibles et aucun processus de sécurité n'est formalisé par écrit.

Pourquoi une Charte de Gouvernance ?

Une charte de gouvernance est le document fondateur qui engage l'ensemble de l'organisation. Elle traduit la volonté de la Direction Générale de prendre en charge les risques liés à la sécurité de manière structurée, traçable et responsable. Sans elle, toute démarche de sécurité reste informelle et juridiquement inopposable.

1.2. Cadre de Référence

La présente charte s'appuie sur les référentiels internationalement reconnus suivants :

- **ISO/IEC 27001** : Norme internationale de management de la sécurité de l'information, définissant les exigences d'un Système de Management de la Sécurité de l'Information (SMSI).
- **ISO/IEC 27005** : Lignes directrices pour la gestion des risques liés à la sécurité de l'information.
- **ISO/IEC 19011 :2018** : Lignes directrices pour l'audit des systèmes de management
- **NIST Cybersecurity Framework** : Référentiel américain structurant la cybersécurité autour de cinq fonctions : Identifier, Protéger, Détecter, Répondre, Récupérer.

1.3. Principes Directeurs

La gouvernance de LiZbiZ repose sur cinq principes fondamentaux non négociables.

Principe 1 — Séparation des fonctions incompatibles. Les fonctions de DSI (mise en œuvre technique) et de RSSI (définition de la politique et contrôle) sont strictement séparées. Elles ne peuvent être exercées par une même personne. Ce principe élimine tout conflit d'intérêt et garantit l'indépendance du contrôle.

Principe 2 — Traçabilité. Toute décision, tout accès et tout incident relatif à la sécurité des systèmes d'information doit être documenté par écrit, horodaté et conservé pendant une durée minimale de cinq ans à des fins d'audit.

Principe 3 — Proportionnalité. Les mesures de sécurité mises en place sont proportionnelles aux risques identifiés et aux enjeux de l'organisation. Elles ne doivent pas entraver inutilement les activités opérationnelles de LiZbiZ.

Principe 4 — Amélioration continue. La gouvernance SSI n'est pas un état figé. Elle est réévaluée régulièrement en fonction de l'évolution des menaces, des technologies et de l'organisation.

Principe 5 — Responsabilité partagée. La sécurité des systèmes d'information est l'affaire de tous les collaborateurs, et non du seul département informatique. Chaque acteur est responsable à son niveau.

1.4. Périmètre d'Application

La présente charte s'applique à l'ensemble des personnes physiques et morales ayant accès aux systèmes d'information de LiZbiZ.Elle couvre l'ensemble des actifs informatiques de LiZbiZ : infrastructures réseau, serveurs, postes de travail, applications métiers, données et systèmes de sauvegarde.

Chapitre 2

Organisation, Rôles et Matrice RACI

2.1. Organigramme de Gouvernance Cible

La restructuration proposée repose sur une séparation claire et formelle des lignes hiérarchiques. Le RSSI est rattaché directement à la Direction Générale, garantissant son indépendance totale vis-à-vis de la DSI. La DSI conserve ses responsabilités techniques mais ne peut plus valider seule les décisions ayant un impact sur la sécurité.

Structure Hiérarchique Cible

Direction Générale (Jean-Pierre L.)

⟶ **RSSI** — rattachement direct, indépendant de la DSI
⟶ **DSI (Sophie M.)** — mise en œuvre technique
⟶ Équipe Technique (20 personnes)

2.2. Rôles et Responsabilités

2.2.1 Direction Générale

La Direction Générale est l'instance décisionnelle (COMEX) suprême en matière de gouvernance. Elle approuve et signe la présente charte, alloue les budgets nécessaires à la sécurité, arbitre les conflits de priorité entre la DSI et le RSSI, et préside le Comité de Sécurité mensuel.

2.2.2 RSSI — Responsable de la Sécurité des Systèmes d'Information

Le RSSI est le garant de la politique de sécurité de LiZbiZ. Rattaché directement à la Direction Générale, il exerce ses missions en toute indépendance. Ses responsabilités sont les suivantes : définir et faire appliquer la politique de sécurité, conduire les audits internes, alerter la Direction Générale sur tout risque critique, valider les accès aux systèmes sensibles créés par la DSI, animer le Comité de Sécurité mensuel, assurer la veille

réglementaire et technologique, et piloter la réponse aux incidents de sécurité.

2.2.3 DSI — Direction des Systèmes d'Information

La DSI est responsable de la mise en œuvre technique des directives de sécurité définies par le RSSI. Elle gère l'équipe technique, administre les infrastructures et assure la disponibilité des systèmes. Elle ne peut plus valider seule les accès aux systèmes sensibles ni définir unilatéralement les politiques de sécurité.

2.2.4 Équipe Technique

L'équipe technique est chargée de la détection et du signalement des incidents, de l'exécution des procédures de réponse définies par le RSSI, de la mise en œuvre des correctifs et des mises à jour de sécurité, et de la documentation technique des opérations de sécurité.

2.2.5 Comité de Sécurité

Un **Comité de Sécurité mensuel** est instauré, composé du Directeur Général, du RSSI et de la DSI. Il a pour mission d'examiner les incidents du mois écoulé, d'évaluer les risques en cours, de valider les décisions stratégiques et de suivre les indicateurs de sécurité. Un compte-rendu écrit est obligatoire après chaque séance, archivé et accessible pour audit.

2.3. Matrice RACI — Gestion des Incidents Critiques

La matrice RACI ci-dessous met fin à la gestion orale des incidents qui prévalait jusqu'ici chez LiZbiZ. Elle définit formellement le niveau d'implication de chaque acteur pour chaque action critique.

Action	DG	RSSI	DSI	Éq. Tech.
Détection de l'incident	I	A	R	**R**
Qualification et classification	I	**A**	R	C
Décision de réponse	**A**	**C**	R	I
Isolement des systèmes	I	**A**	R	**R**
Collecte des preuves	I	**A**	C	**R**
Communication interne	**A**	**R**	I	I
Communication externe	**A**	**R**	I	I
Mise en place des correctifs	I	**A**	**R**	C
Rapport post-incident	**A**	**R**	C	I
Révision des procédures	A	**R**	C	C

R = Responsible **A** = Accountable **C** = Consulted **I** = Informed

Règle d'Or

La DSI ne peut pas valider les accès aux systèmes sensibles qu'elle crée elle-même. Toute validation d'accès critique requiert obligatoirement l'approbation du RSSI.

Chapitre 3

Processus de Décision et Gestion des Risques

3.1. Processus de décision en matière de sécurité

3.1.1 Niveaux de décision

Toute décision ayant un impact sur la sécurité des systèmes d'information de LiZbiZ est classée selon trois niveaux d'importance.

Niveau 1 — Décision Opérationnelle. Elle concerne les actions courantes de sécurité : mise à jour d'un système, révocation d'un accès standard, application d'un correctif mineur. Elle est prise par le RSSI ou l'équipe technique sous sa supervision, sans validation préalable de la Direction Générale.

Niveau 2 — Décision Tactique. Elle concerne les choix ayant un impact significatif sur l'organisation ou les processus : modification de l'architecture réseau, création d'un accès privilégié, réponse à un incident de niveau intermédiaire. Elle requiert la validation conjointe du RSSI et de la DSI.

Niveau 3 — Décision Stratégique. Elle concerne les orientations majeures : adoption d'un nouveau référentiel, investissement sécurité significatif, gestion d'une crise majeure. Elle est réservée au Comité de Sécurité et requiert l'approbation de la Direction Générale.

3.1.2 Procédure de Validation des Accès

Tout accès aux systèmes sensibles de LiZbiZ suit une procédure de validation formalisée en quatre étapes. Premièrement, la **demande** est formulée par écrit par le responsable métier concerné. Deuxièmement, l'**instruction** est réalisée par la DSI qui évalue la faisabilité technique. Troisièmement, la **validation** est effectuée par le RSSI qui vérifie la conformité à la politique de sécurité. Quatrièmement, l'**enregistrement** est assuré par le RSSI qui documente l'accès accordé, sa durée et les conditions de révocation.

3.2. Identification et Classification des Risques

3.2.1 Méthode d'Évaluation

LiZbiZ adopte une méthode d'évaluation des risques basée sur deux critères : la probabilité d'occurrence et l'impact potentiel. Chaque risque est noté de 1 à 3 sur chacun de ces critères. Le niveau de risque est obtenu par le produit des deux scores.

Risque Identifié	Probabilité	Impact	Niveau
Conflit d'intérêt DSI/RSSI	2	2	**4 — Modéré**
Accès non révoqués	3	2	**6 — Élevé**
Absence de traçabilité	2	3	**6 — Élevé**
Fuite de données internes	2	3	**6 — Élevé**
Absence de PCA	2	3	**6 — Élevé**
Ransomware / cyberattaque	2	3	**6 — Élevé**
Ingénierie sociale	2	2	**4 — Modéré**
Erreur humaine collaborateur	3	1	**3 — Faible**

3.2.2 Traitement des Risques

Pour chaque risque identifié, LiZbiZ adopte l'une des quatre stratégies de traitement suivantes : la réduction (mise en place de mesures de sécurité pour diminuer la probabilité ou l'impact), le transfert (souscription d'une assurance cyber ou externalisation), l'acceptation (pour les risques résiduels jugés tolérables) ou le refus (abandon de l'activité générant le risque).

3.3. Gestion des Incidents

3.3.1 Niveaux de Criticité

Tout incident de sécurité est classé selon trois niveaux de criticité. Le **Niveau 1 — Mineur** désigne un incident sans impact opérationnel significatif, traité par l'équipe technique sous supervision du RSSI dans un délai de 72 heures. Le **Niveau 2 — Majeur** désigne un incident affectant un service ou des données sensibles, nécessitant l'intervention

du RSSI et de la DSI dans un délai de 24 heures. Le **Niveau 3 — Critique** désigne un incident mettant en danger la continuité d'activité ou l'intégrité des données, déclenchant immédiatement la cellule de crise avec la Direction Générale.

3.3.2 Délais de Traitement et Rapport

Tout incident doit être signalé au RSSI dans l'heure suivant sa détection. Un rapport d'incident préliminaire doit être produit dans les 24 heures. Un rapport complet incluant l'analyse des causes et les mesures correctives est exigé dans les 5 jours ouvrés suivant la clôture de l'incident.

Chapitre 4

Contrôle, Conformité et Éthique

4.1. Mécanismes de Contrôle Interne

4.1.1 Fondement : ISO 19011 :2018

Le dispositif d'audit interne de LiZbiZ est structuré conformément à la norme **ISO 19011 :2018** — *Lignes directrices pour l'audit des systèmes de management*. Cette norme fournit le cadre méthodologique applicable à la planification, la conduite et le suivi des audits internes, garantissant leur rigueur, leur objectivité et leur exploitabilité.

ISO 19011 :2018 — Principes Fondamentaux

La norme ISO 19011 :2018 repose sur sept principes que LiZbiZ s'engage à respecter dans la conduite de ses audits internes :

- **Intégrité :** L'auditeur agit avec honnêteté et responsabilité.
- **Présentation impartiale :** Les conclusions sont fidèles et objectives.
- **Conscience professionnelle :** L'auditeur fait preuve de diligence et de discernement.
- **Confidentialité :** Les informations collectées sont protégées.
- **Indépendance :** L'auditeur est libre de toute influence ou conflit d'intérêt.
- **Approche fondée sur les preuves :** Les conclusions reposent sur des éléments vérifiables.
- **Approche fondée sur les risques :** L'audit priorise les domaines à plus fort risque.

4.1.2 Programme d'Audit

Conformément à l'ISO 19011 :2018, LiZbiZ établit un **programme d'audit annuel** validé par la Direction Générale. Ce programme définit le nombre, la nature, la portée et le calendrier des audits à conduire sur l'année. Il prévoit au minimum **deux audits internes par an**, dont un audit complet de la conformité à la présente charte et un audit

ciblé sur les domaines à risque identifiés lors de la revue précédente.

Le programme d'audit est piloté par le RSSI, qui en assure la coordination et le suivi. Il est révisé en cours d'année si un incident majeur ou un changement organisationnel significatif le justifie.

4.1.3 Plan d'Audit et Conduite

Chaque audit fait l'objet d'un **plan d'audit individuel** précisant les objectifs, le périmètre, les critères d'audit, les méthodes utilisées, les personnes auditées et le calendrier d'intervention. Ce plan est communiqué aux audités au moins **cinq jours ouvrés** avant le début de l'audit.

La conduite de l'audit suit les étapes définies par l'ISO 19011 :2018 : réunion d'ouverture, collecte et vérification des informations, formulation des constats, réunion de clôture et production du rapport d'audit. Les constats sont classés en **non-conformités majeures**, **non-conformités mineures** et **points d'amélioration**.

4.1.4 Rapport d'Audit et Suivi

À l'issue de chaque audit, le RSSI produit un **rapport d'audit formel** comprenant le résumé exécutif à destination de la Direction Générale, le détail des constats et non-conformités relevés, les recommandations et actions correctives associées, ainsi que les délais de mise en œuvre. Ce rapport est présenté au Comité de Sécurité et archivé pendant cinq ans.

Le suivi des actions correctives issues de l'audit est assuré par le RSSI et présenté lors du Comité de Sécurité suivant. Toute non-conformité majeure non traitée dans le délai imparti est escaladée à la Direction Générale.

Compétences de l'Auditeur

Conformément à l'ISO 19011 :2018, toute personne conduisant un audit interne chez LiZbiZ doit posséder des compétences en techniques d'audit, en sécurité des systèmes d'information et en réglementation applicable. En l'absence d'auditeur interne qualifié, LiZbiZ fait appel à un **auditeur externe indépendant**, dont le mandat est approuvé par la Direction Générale.

4.1.5 Revues d'Accès

Une revue complète des droits d'accès est réalisée tous les six mois par le RSSI, en collaboration avec la DSI et les responsables métiers. Tout accès non justifié est révoqué immédiatement. Les accès des collaborateurs ayant quitté l'entreprise doivent être

révoqués dans les **24 heures** suivant leur départ.

4.1.6 Journaux d'Activité

Les journaux d'activité (logs) des systèmes critiques sont conservés pendant une durée minimale de **12 mois**. Ils sont protégés contre toute modification ou suppression non autorisée et constituent des éléments de preuve mobilisables lors d'un audit ou d'une investigation.

Séparation des Accès aux Journaux

La DSI ne peut pas accéder aux journaux d'activité la concernant directement, afin de garantir l'intégrité des preuves en cas d'investigation interne. Cet accès est exclusivement réservé au RSSI et, en cas de litige, à un auditeur externe désigné par la Direction Générale.

4.2. Conformité Réglementaire

4.2.1 Cadre Légal Applicable

LiZbiZ s'engage à respecter l'ensemble des obligations légales et réglementaires applicables à la protection des données et à la sécurité des systèmes d'information. Les principaux textes de référence sont la loi de 23 décembre 2024 pour tout traitement de données personnelles , la **loi camerounaise n°2010/012** relative à la cybersécurité et la cybercriminalité, ainsi que les exigences contractuelles imposées par les partenaires et clients de LiZbiZ.

4.2.2 Registre de Conformité

Le RSSI tient à jour un **registre de conformité** recensant l'ensemble des obligations réglementaires applicables, l'état de conformité de LiZbiZ pour chacune d'elles et les actions correctives planifiées en cas d'écart. Ce registre est mis à jour au minimum une fois par an et après tout changement réglementaire significatif.

4.3. Éthique et Obligations des Collaborateurs

4.3.1 Code de Conduite Numérique

Tout collaborateur de LiZbiZ s'engage à respecter les règles suivantes. Il utilise les ressources informatiques de l'entreprise exclusivement à des fins professionnelles. Il ne communique jamais ses identifiants de connexion à un tiers, y compris à ses collègues. Il signale immédiatement au RSSI tout comportement suspect ou toute anomalie détectée sur les systèmes. Il ne tente pas d'accéder à des ressources au-delà de ses droits attribués. Il respecte la confidentialité des données auxquelles il a accès dans le cadre de ses fonctions.

4.3.2 Sanctions

Tout manquement aux règles définies dans la présente charte est susceptible d'entraîner des sanctions disciplinaires proportionnelles à la gravité du manquement. Ces sanctions peuvent aller de l'**avertissement écrit** pour un premier manquement mineur, à la **suspension temporaire des accès** pour un manquement répété ou grave, jusqu'au **licenciement pour faute** en cas de violation délibérée et grave de la politique de sécurité, sans préjudice des poursuites pénales applicables en vertu de la législation camerounaise.

> **● Quality Gate : Signalement des Violations — Canal Dédié**
>
> LiZbiZ met en place un canal de signalement confidentiel permettant à tout collaborateur de signaler une violation de la charte sans crainte de représailles. Ce canal est géré directement par le RSSI. Tout signalement de bonne foi est protégé, qu'il aboutisse ou non à une sanction.

4.4. Gestion des Prestataires Externes

Tout prestataire externe accédant aux systèmes de LiZbiZ doit signer un **accord de confidentialité et de sécurité** avant toute intervention. Ses accès sont strictement limités au périmètre de sa mission, validés par le RSSI et révoqués à l'issue de l'intervention. LiZbiZ se réserve le droit d'auditer les pratiques de sécurité de ses prestataires stratégiques conformément aux lignes directrices de l'ISO 19011 :2018.

Chapitre 5

Communication, Suivi et Amélioration

5.1. Communication Interne

5.1.1 Diffusion de la Charte

La présente charte est communiquée à l'ensemble des collaborateurs, prestataires et partenaires de LiZbiZ dans les 30 jours suivant sa signature. Elle est disponible en permanence sur l'intranet de l'entreprise et remise à chaque nouveau collaborateur lors de son intégration. La prise de connaissance et l'acceptation de la charte sont formalisées par une signature électronique ou manuscrite conservée dans le dossier du collaborateur.

5.1.2 Sensibilisation et Formation

La sécurité des systèmes d'information ne peut être efficace sans une culture de la sécurité partagée par l'ensemble des collaborateurs. LiZbiZ s'engage à organiser au minimum une session de sensibilisation par semestre pour l'ensemble du personnel, portant sur les bonnes pratiques de sécurité, la reconnaissance des tentatives de phishing et d'ingénierie sociale, et les procédures de signalement des incidents. Des formations spécifiques sont également organisées pour les équipes techniques et le management.

5.1.3 Communication en Cas de Crise

En cas d'incident de niveau critique, la communication suit un protocole strict. En interne, la Direction Générale est alertée dans l'heure par le RSSI. Les équipes concernées sont informées par le canal validé par le RSSI, sans diffusion non contrôlée. En externe, toute communication vers les clients, partenaires, médias ou autorités est approuvée par la Direction Générale avant diffusion. Le RSSI prépare les éléments factuels et techniques ; la Direction Générale assure la communication institutionnelle.

● Interdiction de Communication Non Autorisée

> Aucun collaborateur n'est autorisé à communiquer publiquement sur un incident de sécurité affectant LiZbiZ, que ce soit via les réseaux sociaux, la presse ou tout autre canal, sans autorisation expresse de la Direction Générale. Toute violation de cette règle constitue une faute grave.

5.2. Indicateurs de Suivi

5.2.1 Tableau de Bord SSI

Le RSSI produit et présente chaque mois au Comité de Sécurité un tableau de bord SSI comprenant les indicateurs clés suivants :

- **Nombre d'incidents** détectés, qualifiés et résolus au cours du mois écoulé.
- **Délai moyen de résolution** des incidents par niveau de criticité.
- **Taux de conformité** des accès revus lors de la dernière revue périodique.
- **Taux de couverture** des formations et sensibilisations réalisées.
- **Nombre de vulnérabilités** identifiées et corrigées sur les systèmes critiques.
- **Statut des actions correctives** issues des audits internes.

5.2.2 Revue Annuelle de la Charte

La présente charte fait l'objet d'une **révision annuelle** obligatoire, pilotée par le RSSI et approuvée par la Direction Générale. Cette révision prend en compte l'évolution du contexte réglementaire, les enseignements tirés des incidents de l'année, les nouvelles menaces identifiées et les évolutions technologiques et organisationnelles de LiZbiZ. Une révision extraordinaire peut être déclenchée à tout moment en cas d'incident majeur ou de changement organisationnel significatif.

5.3. Amélioration Continue

5.3.1 Retour d'Expérience

Après chaque incident de niveau 2 ou 3, un **Retour d'Expérience (REX)** est obligatoirement organisé dans les **15 jours** suivant la clôture de l'incident. Il réunit le RSSI, la DSI et les équipes techniques concernées. L'objectif est d'identifier les causes profondes

de l'incident, les défaillances du processus ayant permis son occurrence ou retardé sa détection, et les mesures correctives à mettre en place pour éviter toute récurrence.

5.3.2 Plan d'Amélioration

Le RSSI tient à jour un **plan d'amélioration continue** recensant toutes les actions correctives et préventives issues des audits, des REX et des revues périodiques. Chaque action est associée à un responsable, un délai de réalisation et un indicateur de suivi. L'avancement du plan est présenté au Comité de Sécurité mensuel et à la Direction Générale lors de la revue annuelle.

Action	Responsable	Délai	Indicateur
Recruter le RSSI	DG	3 mois	Poste pourvu
Former les équipes	RSSI	6 mois	Taux participation
Mettre en place les logs	DSI	2 mois	Logs actifs
Réviser les accès	RSSI + DSI	1 mois	Accès conformes
Instaurer le Comité	DG + RSSI	1 mois	1ère réunion tenue

Conclusion Générale

La présente charte de gouvernance constitue la réponse structurée et formelle aux lacunes organisationnelles identifiées au sein de LiZbiZ. En posant des principes clairs, en définissant des rôles non ambigus, en formalisant les processus de décision et de gestion des risques, en instaurant des mécanismes de contrôle rigoureux et en garantissant une communication maîtrisée, elle offre à LiZbiZ un cadre de sécurité à la hauteur de ses ambitions de croissance.

Sa mise en œuvre effective repose sur trois conditions essentielles. La première est le recrutement rapide d'un RSSI indépendant, condition sine qua non de toute démarche crédible de gouvernance . La deuxième est l'engagement visible et sincère de la Direction Générale, dont le soutien est indispensable pour légitimer la charte aux yeux de l'ensemble des collaborateurs. La troisième est la participation active de tous les acteurs, car la sécurité des systèmes d'information est une responsabilité partagée qui ne peut reposer sur les seules épaules d'un département technique.

Dans un environnement de plus en plus judiciarisé, où les cybermenaces se multiplient et les obligations réglementaires se renforcent, LiZbiZ dispose désormais des fondations nécessaires pour aborder sa prochaine phase de croissance avec la sérénité que confère une gouvernance SSI mature et responsable.

La présente charte entre en vigueur à la date de sa signature par la Direction Générale.

Fonction	Nom	Signature	Date
Directeur Général	Jean-Pierre L.		
DSI	Sophie M.		
RSSI	Poste vacant		